

MediHealth Clinic Cybersecurity Strategy

Author: Titilayo Yusuf

Organisation: MediHealth Clinic - fictional case study

Version: 1.0

Status: Proposed strategy

Date: 5 October 2026

1. Executive Summary

MediHealth Clinic is a fictional Nigerian primary healthcare provider with 50 employees. Its electronic health record (EHR) system processes patient identification details, medical histories, and insurance information.

The supplied scenario describes an EHR server hardware failure, repeated phishing attempts, weak passwords, shared credentials, outdated software, unencrypted EHR communications, and inadequate physical security. It also identifies gaps in documented backup, recovery, and incident response arrangements.

This strategy proposes a phased programme to protect patient information and support dependable clinical services. Initial priorities are to verify recovery capability, assess outdated software, strengthen individual account security, and establish clear reporting and response procedures.

The recommendations have not been implemented or tested. Risk ratings are scenario-based estimates, and actual costs, system capabilities, and regulatory obligations require verification.

2. Scope and Assessment Method

Scope

The assessment covers:

- EHR information, application, and supporting server.
 - Staff accounts and authentication.
 - Staff laptops and portable devices.
 - EHR communications and storage arrangements.
 - Phishing awareness and reporting.
 - Physical access to sensitive areas and equipment.
 - Backup, recovery, and incident response planning.
- No live testing, interviews, system inspection, or access to patient information took place.

Method

The assessment:

1. Recorded the weaknesses supplied in the brief. 2. Identified affected assets. 3. Connected weaknesses to plausible threats and disruptive events. 4. Considered confidentiality, integrity, availability, and patient care. 5. Estimated likelihood and impact. 6. Proposed treatments, owners, and verification activities.

A five-point scale was used for likelihood and impact.

Risk score = Likelihood × Impact.

Priority bands are:

- Low: 1-4.
- Moderate: 5-9.
- High: 10-16.
- Critical: 17-25.

These bands are project conventions rather than measured probabilities.

3. Baseline and Key Limitations

Area	Scenario observation
Availability	Server hardware failure prevented EHR access.
Passwords	Weak passwords are common.
Accountability	Medical personnel share login details.
MFA	Not implemented across clinic systems.
Software	EHR and device software are outdated.
Communications	EHR communications lack encryption.
Storage	Centralised storage with access control policies is not described as established.
Awareness	Basic training exists without a recurring programme.
Physical security	Staff identification and physical security are absent in the scenario.
Recovery and response	Backup/recovery and incident response policies are not documented.

Important unknowns include software versions, network exposure, account permissions, backup capability, hosting architecture, existing monitoring, and available budget.

The absence of a backup policy does not establish that backups are absent. Repeated phishing attempts do not establish a successful breach. The previous server failure does not establish a cyberattack or patient harm.

4. Prioritised Risk Assessment

Risk ID	Risk	Likelihood	Impact	Score	Priority
R01	Phishing-related account compromise	4	4	16	High
R02	Misuse of weak or shared credentials	4	4	16	High
R03	Exploitation of outdated software	4	5	20	Critical
R04	Interception of unencrypted EHR communications	3	4	12	High
R05	Extended EHR outage with ineffective or unclear recovery	3	5	15	High
R06	Unauthorised physical access	3	4	12	High

Outdated software receives the highest initial score because exploitation could affect several systems and seriously disrupt services. This rating requires validation against actual versions, vulnerabilities, exposure, and controls.

Recovery verification remains an immediate priority despite its lower score because a disruption has already occurred and usable backups are essential to recovery.

Equal scores do not imply identical urgency. Patient care, existing exposure, implementation dependencies, and new evidence should guide decisions.

5. Phishing Awareness Campaign

Objective

Help staff recognise suspicious messages, verify requests independently, and report concerns promptly.

Materials Prepared

The campaign includes:

- A fictional insurance account verification email.
- Warning signs and safe response guidance.
- A 30-minute training outline.
- A training presentation.
- A proposed phishing simulation plan.

The examples use fictional details and do not contain patient information.

Main Learning Messages

Staff should:

- Pause when a message applies pressure.
- Inspect the full sender address and request.
- Verify through an established contact or trusted portal.
- Report suspicious messages and accidental interactions promptly.

The training also explains SPF, DKIM, and DMARC as supporting checks. Passing authentication does not establish that a request is safe.

Evaluation

The proposed evaluation compares baseline and follow-up exercises using:

- Reporting rate.
- Confirmed human click rate.
- Reporting time.
- Knowledge-check performance.

Automated email scanning must be considered when interpreting clicks. Differences in exercise difficulty must also be considered.

Any real simulation requires prior approval, tested delivery, appropriate data handling, and protection of clinical operations.

No training or simulation has been conducted.

6. Password Security Strategy

The proposed password policy introduces:

- Individual accounts.
- A 15-character minimum for user account passwords.
- Long passphrases and unique passwords.
- Rejection of common or compromised passwords where supported.
- Event-driven password changes.
- Secure recovery and reporting.
- Documented exceptions for incompatible systems.

Mandatory character mixtures and routine expiration are not the proposed defaults. This is an explained departure from the older project brief, informed by current NIST guidance.

Bitwarden Business Password Manager is proposed for evaluation. Adoption depends on compatibility, administration, recovery, cost, and vendor assessment.

Staff must not share personal EHR credentials, even through an approved password manager.

7. MFA Implementation Strategy

Prioritise administrators, email, remote access where present, and supported EHR access.

Prefer FIDO2/WebAuthn authentication configured with user verification. Where unavailable, assess authenticator codes or push with number matching as interim methods.

Document the remaining phishing risk and migration requirements.

Before enforcement:

- Confirm system compatibility.
- Address shared accounts.
- Establish recovery and emergency access.
- Pilot with representative employees.
- Test relevant bypass routes.
- Obtain clinical acceptance.

The proposed rollout spans six weeks, subject to resources and vendor dependencies.

For a legacy EHR, assess supported upgrades or integration. A protected gateway is useful only if direct access cannot bypass its controls.

8. Technical and Physical Improvements

Software Maintenance

Create an inventory of versions and support status.

Prioritise confirmed exposure and exploitable weaknesses. Test changes before deployment to critical systems and plan replacement of unsupported software.

Communication Security

Identify insecure EHR connections and enable supported transport encryption.

Verify certificates and application behaviour before disabling older connections.

Storage and Access

Establish where patient information resides and who can access it.

Use approved managed storage, role-based permissions, and appropriate activity logging. Centralisation alone does not guarantee security.

Physical Access

Introduce staff identification, visitor procedures, restricted sensitive areas, and secure equipment storage.

Enable suitable screen locking and assess how protections work at shared clinical workstations.

9. Backup and Recovery Strategy

First verify existing backup coverage, protection, job results, and restoration capability.
The proposed plan covers EHR data, attachments, configuration, essential documents, and recovery resources.
Protected copies should include an off-site arrangement and an offline or suitably isolated immutable copy.
Encryption keys and recovery credentials must remain available during an outage.

Proposed Recovery Targets

Service	RTO	RPO
EHR and essential associated information	4 hours	1 hour
Essential administrative documents	1 working day	24 hours

These are discussion targets requiring business impact assessment, clinical approval, funding, and testing.
Proposed testing includes monthly selected-data restoration, quarterly isolated EHR recovery, and six-monthly downtime exercises.
Clinical staff must validate restored workflows and reconcile downtime records before normal operation resumes.

10. Incident Response and Clinical Continuity

The response plan defines reporting, assessment, severity, containment, evidence preservation, remediation, recovery, and review.
Assign an incident coordinator, IT lead, clinical lead, management decision-maker, and appropriate privacy or legal support.
Prepared response guides cover:

- Phishing with exposed credentials.
- Suspected ransomware.
- Lost or stolen devices.
- Suspected patient record alteration.

Containment decisions must account for immediate clinical impact. Major disruptive actions require agreed authority and escalation arrangements.
Preserve relevant evidence and use trusted alternative communications if email is compromised.
System restoration does not resolve whether information was previously stolen. Confidentiality impacts require separate assessment.

11. Regulatory and Governance Context

Nigeria's Data Protection Act 2023 is a relevant starting point for assessing the clinic's data protection obligations.

Before implementation, review applicable requirements for information handling, vendors, retention, incident notifications, and other relevant obligations.

The brief mentions HIPAA, but its applicability cannot be inferred solely from the clinic's healthcare activities. Assess whether the clinic has a qualifying role or relationship within HIPAA's scope.

NIST and CISA publications are technical references. They are not presented as Nigerian laws.

Management should approve policies, appoint accountable owners, maintain an exception register, and review residual risks.

This strategy is not a legal assessment or compliance certification.

12. Implementation Roadmap

Period	Priorities	Proposed owners	Evidence expected
Days 1-7	Verify backups; assess software exposure; identify shared and privileged accounts; establish incident reporting	IT lead, clinical lead, management	Verification records, initial inventory, reporting procedure
Days 8-30	Begin awareness training; introduce individual accounts; pilot MFA; plan patching and encryption; document recovery	IT lead, managers, vendors	Training records, pilot results, approved treatment plans
Days 31-60	Extend MFA; complete feasible technical fixes; improve physical access; test recovery and response	IT lead, clinical lead, facilities lead	Enforcement records, test reports, access procedures
Days 61-90	Review effectiveness; reassess risks; resolve or renew exceptions; plan remaining upgrades	Management and control owners	Updated risk register, action tracking, approved residual risks

The roadmap and MFA schedule must be reconciled after discovery. Vendor delays may extend specific actions.

13. Resources and Feasibility

Costs have not been estimated because products, licences, infrastructure, and vendor requirements are unknown.

Prepare a costed proposal covering:

- Authentication licences and devices.
- Backup storage and recovery equipment.
- EHR vendor support or upgrades.
- Password manager subscriptions.
- Staff training and support time.
- Physical access improvements.
- Specialist incident support.

Prioritise actions based on risk reduction and clinical continuity. Obtain evidence before claiming that a recommendation is affordable or technically feasible.

14. Monitoring and Success Measures

Area	Proposed measure
Awareness	Reporting rate, confirmed click rate, and knowledge-check results
Account security	Individual-account coverage and resolved shared-account exceptions
MFA	Enforcement coverage and phishing-resistant coverage
Software	Supported asset coverage and outstanding prioritised weaknesses
Recovery	Age of usable recovery points and tested RTO/RPO performance
Response	Reporting, escalation, containment, and recovery times
Governance	Corrective action completion and overdue exceptions

Measurements require defined owners, reliable data, and agreed review intervals.

No improvement percentages or residual risk reductions are claimed.

15. Conclusion

MediHealth Clinic's proposed strategy connects security improvements to patient information protection and dependable care.

The first decisions should establish what controls actually exist, whether recovery works, and which systems face the most urgent exposure.

Implementation should proceed in stages, with clinical involvement, documented ownership, and verification before risks are marked as reduced.

16. Supporting Deliverables

- Scope and baseline
- Asset and threat assessment
- Risk register
- Sample phishing email
- Training outline
- Simulation plan
- Password security policy
- MFA implementation plan
- Backup and recovery plan
- Incident response plan

17. References

- Mama CyberShield Cohort 2.0 Project Work, Project Topic 1.
- Nigeria Data Protection Commission - Nigeria Data Protection Act 2023: [View source](#)
- HHS - Covered Entities and Business Associates: [View source](#)
- NIST SP 800-63B-4: [View source](#)
- NIST SP 800-61 Rev. 3: [View source](#)
- NIST SP 800-34 Rev. 1: [View source](#)
- CISA - #StopRansomware Guide: [View source](#)
- CISA - Implementing Phishing-Resistant MFA: [View source](#)

18. Project Status

Assessment and strategy documents prepared for a fictional educational scenario.

Recommendations remain proposed. No live assessment, control deployment, training delivery, simulation, or operational exercise has been performed.